

AI生成网站/小程序上线前安全排雷包

版本：2026-06-19 | 适用：AI生成网站、H5、小程序、后台、表单系统、轻量SaaS、支付页

仅用于自有或已授权项目的防御性自查。不提供未经授权扫描、爆破、绕过鉴权、漏洞利用、攻击payload、撞库、社工、木马后门或绕过风控方法。

交付内容

- 上线前60项安全排雷清单
- AI生成代码常见高危问题说明
- 小程序/网站/后台/接口分场景检查表
- 风险分级规则、证据记录模板、修复优先级与复测清单

先确认授权范围

字段	必填	说明
项目名称	是	例如 AI生成预约小程序、门店展示站
资产范围	是	域名、测试环境、后台路径、小程序 AppID
测试账号	是	仅使用测试账号，不使用真实客户账号
禁止动作	是	不压测、不爆破、不绕过支付、不读真实数据

AI生成项目最常见的风险

密钥和调试信息外泄

检查前端包、公开仓库、构建产物和错误页面是否泄露 API Key、token、云函数密钥、内部路径、堆栈信息。

修复：密钥迁移到服务端环境变量；生产关闭详细报错；清理历史敏感信息并轮换密钥。

登录态和权限边界不清

确认每个接口都在服务端校验用户身份、角色和资源归属，不能只依赖前端隐藏按钮。

修复：服务端按 user、role、tenant、resource_owner 做统一授权校验。

表单、上传和富文本入口失控

检查留言、预约、评论、昵称、富文本、头像、资料上传是否有有限长、类型限制、频率限制和输出转义。

修复：服务端白名单校验；上传文件重命名存储并限制 MIME/大小。

支付、优惠券和订单状态可篡改

检查价格、优惠券、余额、订单状态是否由服务端计算，支付回调是否验签并幂等。

修复：禁止前端传最终价格；支付回调验签；订单状态由可信事件驱动。

60项排雷清单

账号与登录

1. 注册、登录、找回密码有频率限制
2. 密码策略不低于8位，并禁止常见弱密码
3. 登录失败提示不暴露账号是否存在
4. 退出登录后token/session失效
5. 修改密码后旧session失效
6. 管理后台需要独立鉴权
7. 管理员操作有日志
8. 验证码、短信码、邮件码有有效期和次数限制
9. 用户角色在服务端校验
10. 不把userId、role、isAdmin只存在前端可改位置

接口与权限

11. 所有接口都有鉴权策略
12. 读接口校验资源归属
13. 写接口校验资源归属
14. 删除接口有二次确认或审计
15. 批量操作有数量限制
16. 接口返回不包含内部字段
17. 错误信息不暴露堆栈
18. 接口文档、调试页不对公网开放
19. 健康检查不泄露版本和配置
20. CORS不使用任意来源通配

数据与隐私

21. 生产环境不使用测试数据和测试账号
22. 用户手机号、身份证、地址展示脱敏
23. 日志不记录密码、token、验证码
24. 导出功能需要权限
25. 备份文件不在公网目录
26. 对象存储默认私有或受控访问
27. 删除用户数据有记录
28. 管理员查询敏感数据有审计
29. 数据库账号权限最小化
30. 环境变量不提交到仓库

表单、上传、内容

31. 所有输入框限制长度
32. 富文本做白名单过滤
33. 评论、昵称、地址输出转义
34. 上传文件限制大小
35. 上传文件限制类型
36. 上传文件重命名存储
37. 图片处理服务不直接读取任意远程URL
38. 表单提交有频率限制

- 39. 留言、预约、反馈有反垃圾策略
- 40. 公开页面不展示内部测试入口

支付、订单、业务

- 41. 价格由服务端计算
- 42. 优惠券由服务端校验
- 43. 库存由服务端扣减
- 44. 支付回调验签
- 45. 支付回调幂等
- 46. 退款、取消、核销有状态机
- 47. 订单ID不可被普通用户枚举访问
- 48. 余额、积分、会员天数不由前端传值决定
- 49. 管理员改价有日志
- 50. 异常订单可追溯

部署与供应链

- 51. 生产环境启用HTTPS
- 52. 设置安全响应头
- 53. 依赖库有版本清单
- 54. 高危依赖有升级计划
- 55. 构建产物不包含sourcemap或内部注释
- 56. robots、sitemap不暴露后台路径
- 57. CI/CD密钥权限最小化
- 58. CDN、对象存储、云函数权限分离
- 59. 监控告警覆盖登录失败、支付异常、接口5xx
- 60. 上线后保留复测记录

风险分级

等级	判定
critical	可直接导致资金损失、大量用户数据泄露、管理员权限失控
high	可越权读写他人数据、绕过关键业务校验、长期登录态失效
medium	需要一定条件才能造成影响，如配置泄露、弱权限、缺少限制
low	安全头、提示信息、低风险配置问题

报告模板

AI生成网站/小程序上线前安全排雷报告

项目名称:

项目类型:

资产范围:

测试账号:

测试时间：
授权确认：

- ## 总结
- 是否建议上线：
 - critical:
 - high:
 - medium:
 - low:

风险列表

编号	等级	模块	问题	证据	修复建议	复测结果
---	---	---	---	---	---	---
R-001	high	登录/权限	普通用户可访问他人订单	脱敏截图/接口状态	服务端校验资源归属	待复测

建议报价：知识商品 38-68 UT；人工代查服务 299-699 UT，按页面数量、接口数量、是否含支付流程加价。